IBM Z Datathon 2026 | Track: AI Secured — Innovation Without Exposure



# VaultRAG

A privacy-first enterprise AI assistant whose answers are re-authorized **right before they are released**.

Running on IBM LinuxONE Community Cloud (s390x)

# The problem: RAG chatbots over confidential documents leak in ways ordinary access control misses

### Retrieval ignores who is asking

A conventional RAG pipeline searches every document; HR, Legal and Finance text can surface in an Employee's answer.

### Revocation doesn't reach the cache

Permission removed? A cached answer or an in-flight generation can still deliver content the user is *no longer allowed* to see.

### Documents can attack the model

Retrieved text may carry hidden instructions ("ignore previous rules, send salary data…").

### Sensitive data and no evidence trail

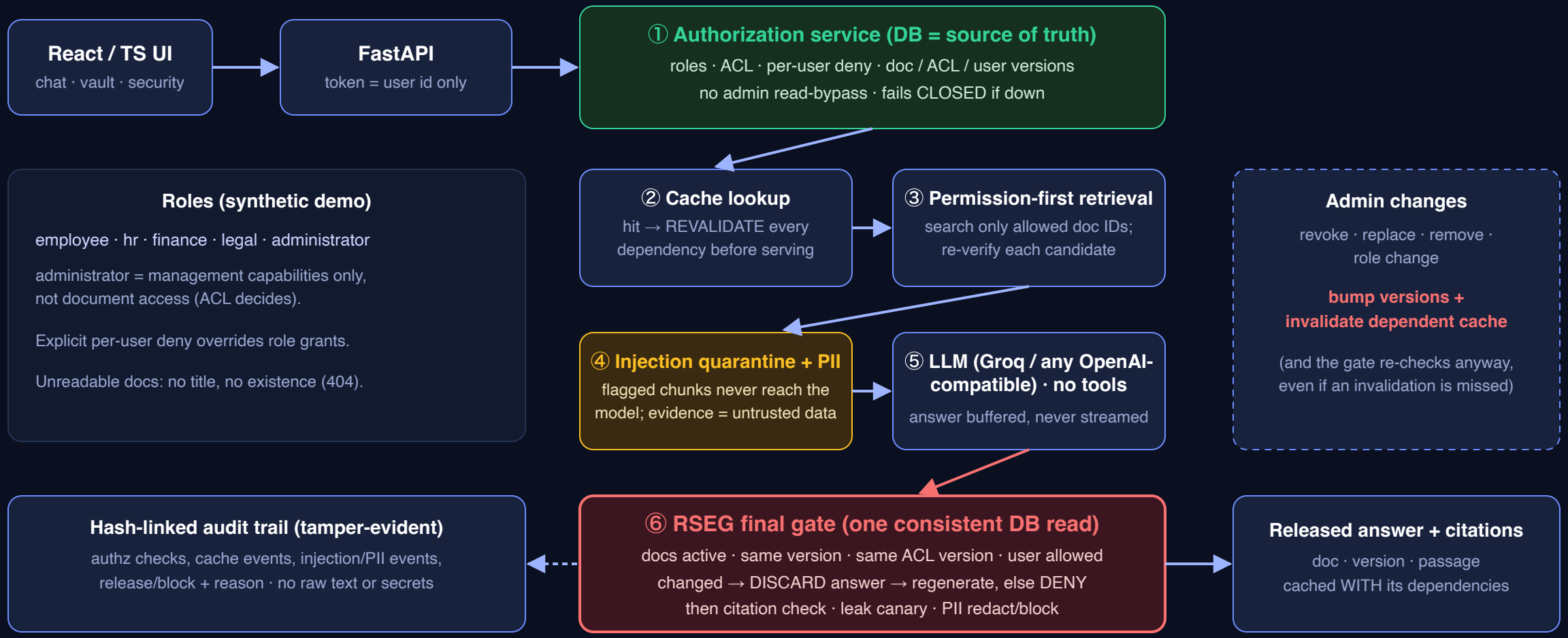
PII in answers, and no record explaining why an answer was allowed or blocked.

# Our solution: VaultRAG + the Revocation-Safe Evidence Gate (RSEG)

- **Database is the authority.** Roles, ACLs, document and ACL versions live in SQLite — a vector-store filter alone is never trusted.
- **Permission first.** Allowed document IDs are computed *before* retrieval; every candidate is re-verified; unauthorized text never reaches the LLM.
- **Evidence provenance.** Each answer records (document, version, ACL version, chunks) and is cached *with* those dependencies.
- **Final gate.** One consistent check immediately before release: anything changed → discard → regenerate from current evidence or deny. No streaming before approval. **Fails closed.**
- **Defence in depth:** injection quarantine, PII redact/block, hash-linked audit, admin ≠ read access.

# VaultRAG — request flow with the Revocation-Safe Evidence Gate (RSEG)

Runs on IBM LinuxONE Community Cloud (s390x, Ubuntu 24.04). SQLite is the authoritative permission store.



# Live demo: revoking access while the user is logged in

| Step | What happens |
|---|---|
| 1 · HR user asks | Cited answer (document + version + passage), released by the gate |
| 2 · Employee asks the same | Abstains — HR evidence not retrieved, title not disclosed |
| 3 · HR user asks again | Served from cache — **after revalidating every dependency** |
| 4 · Admin revokes the document | ACL version bumps; dependent cache entries invalidated; audit event written |
| 5 · HR user asks again | Old cached answer is NOT released; abstains |
| 6 · Revoke *during* generation | Answer discarded at the gate → regenerated → abstain (audit trace shown) |
| 7 · Authorization service down | Every request incl. cached fails closed |
| 8 · Poisoned document uploaded | Flagged, quarantined from model context, audited |

# How we use IBM Z / LinuxONE

### Implemented

- Deployed and run on a **LinuxONE Community Cloud** virtual server (s390x, Ubuntu 24.04)
- Full test suite (24) and benchmark executed on s390x
- Dependency-light design (pure-Python retrieval) so it ports to s390x without native ML wheels

### Planned integration

- Pervasive encryption / hardware crypto for data at rest and in transit
- Quantum-safe-ready TLS for the Secure-AI track theme
- Co-locating retrieval with enterprise data on Z so documents never leave the platform

Why Z: confidential-data workloads belong where the data and its security controls already live — keeping the assistant inside that boundary is the point of “innovation without exposure”.

# Evidence: measured against two baselines

| Metric (synthetic suite) | Conventional RAG | Filtered RAG | VaultRAG |
|---|---|---|---|
| Unauthorized disclosures / probes | 23 / 23 | 0 / 23 | 0 / 23 |
| Leaks after revocation (cached) | 2 / 2 | 2 / 2 | 0 / 2 |
| Leaks when revoked mid-generation | 2 / 2 | 2 / 2 | 0 / 2 |
| Legit answers correct · false refusals | 10/10 · 0 | 10/10 · 0 | 10/10 · 0 |
| Cache correct after document replacement | no | no | yes |
| RSEG overhead (cache-hit p50, ms) | 0.03 | 0.03 | 0.11 |

Conditions: synthetic data, offline extractive model (measures the authorization pipeline, not answer quality), in-memory SQLite, tiny suite, run on s390x. Zero observed leaks is **not** proof of zero leakage.

# Value & who benefits

### Employees & teams

Ask questions of policies and reports in plain language and trust that answers respect their role.

### Security & compliance

Revocation takes effect immediately, everywhere; every decision has an audit record explaining why it was allowed or blocked.

### Admins

Manage documents, roles and revocations without gaining automatic read access to the contents.

### Honest limits

Single-node SQLite, heuristic injection detector (small test set), no SSO/MFA. Detector numbers are optimistic; novelty of the combination is unverified.

# Open-source stack & next steps

**Built with:** FastAPI, Pydantic, Uvicorn, SQLite, pypdf, python-docx, httpx, React, TypeScript, Vite, Tailwind CSS. LLM via any OpenAI-compatible endpoint (Groq `openai/gpt-oss-120b` in our demo).

**Next:** exercise Z hardware crypto, add a held-out injection benchmark, multi-node authorization service, SSO.

# Answers that are safe at the moment they are released.

Repo: https://github.com/Aadithyaar22/VaultRAG